Security Requirements Table – Hospital Management System

Security ID	Description	Priority	Acceptance Criteria	Rationale
SE-01	The system shall authenticate users before granting access to the Hospital Management System.	High	Users must provide valid login credentials to access the system. Invalid credentials must be rejected.	Prevents unauthorized access to the system.
SE-02	The system shall implement role-based access control for patients, doctors, and hospital staff.	High	Each user must access only the features and information permitted by their assigned role.	Prevents unauthorized access to sensitive information and functions.
SE-03	The system shall protect patient medical records from unauthorized access.	High	Only authorized users with appropriate permissions can view or modify patient medical records.	Ensures patient confidentiality and data privacy.
SE-04	The system shall encrypt sensitive patient information during transmission and storage.	High	Sensitive information must be encrypted during transmission and stored using approved encryption mechanisms.	Protects confidential medical information from exposure.
SE-05	The system shall verify user identity through OTP verification where required.	Medium	The system must validate the OTP before completing the protected operation. Invalid or expired OTPs must be rejected.	Reduces the risk of unauthorized account access.
SE-06	The system shall maintain an audit trail of access to and modifications of sensitive patient records.	High	The system must record the user, activity, timestamp, and affected record for relevant operations. Audit records must not be modifiable by unauthorized users.	Supports accountability and investigation of suspicious activities.
SE-07	The system shall enforce secure session management for authenticated users.	Medium	Sessions must expire after the configured inactivity period, and users must be able to log out securely.	Reduces the risk of unauthorized access through unattended sessions.
SE-08	The system shall restrict access to medical reports, prescriptions, and diagnostic scans to authorized users.	High	Only users with the required permissions can view or download these files. Unauthorized requests must be denied.	Protects sensitive medical documents from unauthorized disclosure.
SE-09	The system shall validate user inputs to prevent common application security vulnerabilities.	High	Inputs must be validated on the server, and malicious input must not execute unauthorized database queries or scripts.	Helps prevent SQL injection, cross-site scripting, and related attacks.
SE-10	The system shall protect payment information during payment processing.	High	Payment information must be transmitted securely, and sensitive payment credentials must not be stored in plaintext.	Protects financial information and reduces payment-related security risks.
SE-11	The system shall restrict the modification and deletion of medical records to authorized personnel.	High	Unauthorized modification or deletion attempts must be denied and recorded in the audit trail.	Maintains the integrity and reliability of patient records.
SE-12	The system shall securely manage password storage and password-related operations.	High	Passwords must be stored using an approved salted password-hashing algorithm. Password reset operations must verify the user's identity.	Prevents exposure of user passwords and reduces account compromise risks.
SE-13	The system shall enforce access restrictions on patient information exported or downloaded from the system.	Medium	Downloads must be permitted only to authorized users, and unauthorized download attempts must be denied.	Reduces the risk of sensitive information being leaked outside the system.
SE-14	The system shall protect against repeated failed login attempts.	Medium	The system must apply a configured rate limit or temporary lockout after repeated unsuccessful authentication attempts.	Helps prevent brute-force password attacks.
SE-15	The system shall maintain secure backups of critical hospital data.	Medium	Backups must be access-controlled, protected against unauthorized modification, and periodically tested for successful restoration.	Supports data recovery and continuity of hospital operations.